

Checklist

Security Education

Program Design

- ☐ Define 1-2 clear, achievable security-awareness objectives.
- ☐ Tailor training to the organization's specific risks and threat landscape.
- ☐ Obtain executive support and align the program with organizational culture.
- ☐ Treat security awareness as an ongoing process, not a once-a-year compliance exercise.
- ☐ Reinforce training regularly using repetition and spaced learning.
- ☐ Include realistic, hands-on exercises such as phishing simulations.
- ☐ Teach users how security lessons apply to their everyday work.

Establish a Baseline

- ☐ Measure users' current security knowledge and behavior before launching the program.
- ☐ Conduct realistic exercises to identify common weaknesses.
- ☐ Assess how users currently react to phishing, suspicious links, and unusual requests.
- ☐ Use baseline results to set measurable improvement targets.

Rules and Guidelines

- ☐ Create clear and concise program rules.
- ☐ Ensure instructions are consistent with organizational policies and culture.
- ☐ Get input from employees and stakeholders at different levels.
- ☐ Clearly explain what users should do when they encounter suspicious activity.
- ☐ Make reporting suspicious emails or incidents simple and accessible.

Training and Reinforcement

- ☐ Reinforce key lessons through repeated practice.
- ☐ Teach users to hover over and verify links before clicking.
- ☐ Train users to recognize suspicious emails, requests, and social-engineering tactics.
- ☐ Encourage users to report mistakes and suspicious activity quickly.
- ☐ Use examples that closely resemble real-world threats.
- ☐ Supplement computer-based training with interactive awareness activities.

Positive Reinforcement

- ☐ Make it clear that users will not be punished for reporting a mistake.
- ☐ Encourage reporting even when a user has already clicked a malicious link.
- ☐ Reward good security behavior and participation.
- ☐ Consider gamification, competitions, recognition, or small incentives.
- ☐ Maintain a supportive learning environment instead of relying on fear or shame.

Incident Response

- ☐ Define what users should do after identifying or falling for an attack.
- ☐ Test existing incident-response procedures during awareness exercises.
- ☐ Identify gaps, inconsistencies, or inefficiencies in response processes.
- ☐ Update procedures and policies based on lessons learned.

Metrics to Track

- ☐ Number of simulated phishing emails sent.
- ☐ Number or percentage of emails opened.
- ☐ Number or percentage of malicious links clicked.
- ☐ Number of credentials submitted during simulations.
- ☐ Number of phishing attempts reported.
- ☐ Number of suspicious emails not reported.
- ☐ Number of users accessing training or awareness resources.
- ☐ Changes in reporting rates over time.
- ☐ Changes in phishing click rates over time.
- ☐ Progress toward established security-awareness goals.

Measure Overall Success

- ☐ Compare current results against the original baseline.
- ☐ Look for increased reporting of suspicious activity.
- ☐ Look for a decrease in successful phishing or malware incidents.
- ☐ Track reductions in risky user behavior.
- ☐ Review metrics periodically rather than relying on a single assessment.
- ☐ Adjust training topics based on emerging threats and performance data.
- ☐ Update program objectives as the organization's security maturity improves.

Final Review

- ☐ Confirm users understand that security is part of their responsibility.
- ☐ Confirm training focuses on behavior change, not just course completion.
- ☐ Keep the program engaging, relevant, and easy to participate in.
- ☐ Continue reinforcing good habits over time.
- ☐ Use encouragement and positive reinforcement rather than punishment.